ΠΑΝΕΠΙΣΤΗΜΙΟ ΠΑΤΡΩΝ
UNIVERSITY OF PATRAS

Τμήμα Μηχανικών Η/Υ και Πληροφορικής

Εισαγωγή στα Πληροφοριακά Συστήματα

Εξαμηνιαία Εργασία 2025-2026

Zero Trust Security και Προστασία Επιχειρησιακών Πληροφοριακών Συστημάτων

Γεώργιος Τσομπανάκης 1104819

Μιχαήλ – Αριστείδης Γκουλάλα 1100521

Χριστόφορος Θεοδοσόπουλος 1100557

Περιεχόμενα

1. Εισαγωγή

1.1 Επιχειρησιακά Πληροφοριακά Συστήματα

Τα Πληροφοριακά Συστήματα αποτελούν σύνολα διασυνδεδεμένων διαδικασιών που υποστηρίζουν βασικές επιχειρησιακές λειτουργίες, τη λήψη αποφάσεων, την ανάλυση δεδομένων, καθώς και την επικοινωνία και τον συντονισμό σε μία επιχείρηση. Αποτελούν βασικό μοχλό ανάπτυξης, επιτρέποντας τη βελτιστοποίηση διαδικασιών και την προσαρμογή στις μεταβαλλόμενες συνθήκες της αγοράς.
Τα σύγχρονα πληροφοριακά συστήματα βασίζονται σε κατανεμημένες αρχιτεκτονικές και υποδομές cloud, επιτρέποντας απομακρυσμένη πρόσβαση από πολλαπλές συσκευές και τοποθεσίες. Πλατφόρμες όπως της Microsoft και της Oracle υποστηρίζουν αυτή τη μετάβαση. Ωστόσο, η αυξημένη διασυνδεσιμότητα ενισχύει την πολυπλοκότητα και εκθέτει τα συστήματα σε περισσότερους κινδύνους, καθιστώντας την ασφάλεια κρίσιμο παράγοντα για τη διασφάλιση της ακεραιότητας και της διαθεσιμότητάς τους.

1.2 Παραδοσιακό Μοντέλο Ασφάλειας

Το παραδοσιακό μοντέλο ασφάλειας, γνωστό ως περιμετρική ασφάλεια, βασίζεται στη δημιουργία ενός προστατευτικού ορίου που διαχωρίζει το εσωτερικό, έμπιστο δίκτυο από το εξωτερικό, μη έμπιστο περιβάλλον. Η ασφάλεια επικεντρώνεται στον έλεγχο της δικτυακής κίνησης μέσω τεχνολογιών όπως firewalls και συστήματα ανίχνευσης ή αποτροπής

εισβολών.
Κεντρική αρχή του μοντέλου είναι ότι οι οντότητες εντός του δικτύου θεωρούνται αξιόπιστες μετά την επιτυχή διέλευση από την περίμετρο. Το μοντέλο αυτό σχεδιάστηκε για περιβάλλοντα με σαφώς οριοθετημένες υποδομές και κεντρικό έλεγχο πρόσβασης.

1.2.1 Περιορισμοί και Αποτυχία του Παραδοσιακού Μοντέλου

Παρά την αρχική του αποτελεσματικότητα, το μοντέλο παρουσιάζει σημαντικές αδυναμίες στις σύγχρονες υποδομές. Η εξάρτηση από σαφώς οριοθετημένο δίκτυο καθίσταται προβληματική λόγω της υιοθέτησης cloud υπηρεσιών και απομακρυσμένης πρόσβασης, που καθιστούν την έννοια της περιμέτρου ασαφή.
Επιπλέον, η υπόθεση εμπιστοσύνης προς το εσωτερικό δίκτυο περιορίζει τον έλεγχο εντός αυτού, επιτρέποντας σε έναν επιτιθέμενο που αποκτά πρόσβαση να κινηθεί ανεμπόδιστα. Οι περιορισμοί αυτοί καθιστούν το μοντέλο ανεπαρκές για τα σύγχρονα πληροφοριακά συστήματα, αναδεικνύοντας την ανάγκη για πιο δυναμικές και προσαρμοστικές προσεγγίσεις ασφάλειας.

1.3 Μοντέλο Zero Trust

Το μοντέλο Zero Trust αποτελεί μία σύγχρονη προσέγγιση ασφάλειας που απορρίπτει την υπόθεση εμπιστοσύνης εντός του δικτύου. Βασίζεται στην αρχή “never trust, always verify”, απαιτώντας συνεχή επαλήθευση χρηστών και συσκευών ανεξαρτήτως τοποθεσίας.
Η λειτουργία του στηρίζεται σε αρχές όπως η ρητή επαλήθευση, η ελάχιστη πρόσβαση και η υπόθεση παραβίασης. Κάθε αίτημα αξιολογείται δυναμικά με βάση παράγοντες όπως η ταυτότητα χρήστη και η κατάσταση της συσκευής.
Στα επιχειρησιακά πληροφοριακά συστήματα εφαρμόζεται μέσω

μηχανισμών όπως πολυπαραγοντική αυθεντικοποίηση και έλεγχος πρόσβασης σε επίπεδο πόρου. Αντιμετωπίζει τους περιορισμούς του παραδοσιακού μοντέλου, παρέχοντας πιο ευέλικτη και προσαρμοστική ασφάλεια σε κατανεμημένα περιβάλλοντα.
Στο πλαίσιο αυτό, η παρούσα εργασία εξετάζει συγκριτικά το παραδοσιακό μοντέλο και το Zero Trust, αναδεικνύοντας τα πλεονεκτήματα της δεύτερης προσέγγισης για τα σύγχρονα επιχειρησιακά πληροφοριακά συστήματα.

2. State of the art

2.1 Θεμελιώδεις Αρχές Zero Trust

1. Ρητή επαλήθευση (Verify explicitly)
Η αρχή της ρητής επαλήθευσης επιβάλλει ότι κάθε αίτημα πρόσβασης σε επιχειρησιακούς πόρους πρέπει να ελέγχεται και να επαληθεύεται συνεχώς, ανεξαρτήτως της προέλευσής του. Σε αντίθεση με τα παραδοσιακά μοντέλα, η επαλήθευση δεν πραγματοποιείται μόνο κατά την αρχική είσοδο στο σύστημα, αλλά καθ' όλη τη διάρκεια της συνεδρίας, με βάση δεδομένα όπως η ταυτότητα χρήστη, η συσκευή και το περιβάλλον πρόσβασης.

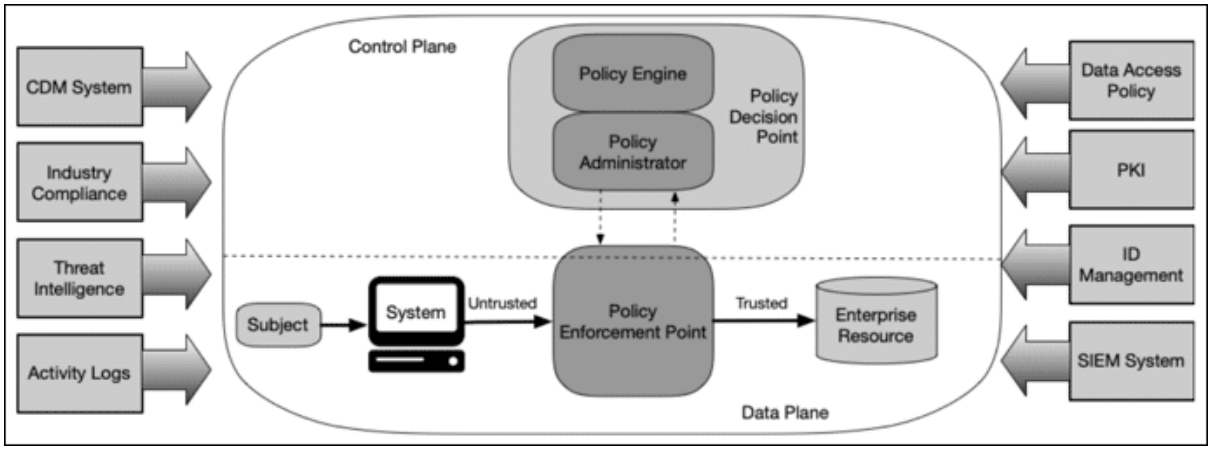
2. Πρόσβαση με ελάχιστα δικαιώματα (Least privilege access)
Η αρχή αυτή προβλέπει ότι κάθε χρήστης ή σύστημα διαθέτει μόνο τα απολύτως απαραίτητα δικαιώματα για την εκτέλεση των απαιτούμενων εργασιών. Με τον τρόπο αυτό περιορίζεται η έκταση πιθανής ζημιάς σε περίπτωση παραβίασης, καθώς μειώνεται η πρόσβαση σε κρίσιμους πόρους.

3.Θεώρηση παραβίασης ως δεδομένης (Assume breach)
Η προσέγγιση Zero Trust βασίζεται στην υπόθεση ότι ένα σύστημα μπορεί ήδη να έχει παραβιαστεί. Για τον λόγο αυτό, εφαρμόζονται συνεχείς έλεγχοι και μηχανισμοί περιορισμού της πρόσβασης, με στόχο την αποτροπή

εξάπλωσης πιθανών επιθέσεων και τη διασφάλιση της λειτουργίας των συστημάτων.

2.2 Αρχιτεκτονική Zero Trust

Η αρχιτεκτονική Zero Trust, σύμφωνα με το National Institute of Standards and Technology, δεν αποτελεί ένα συγκεκριμένο προϊόν αλλά ένα εννοιολογικό μοντέλο που καθορίζει τον τρόπο με τον οποίο ελέγχεται η πρόσβαση σε πόρους. Βασίζεται στη συνεχή αξιολόγηση εμπιστοσύνης και στον διαχωρισμό των λειτουργιών ελέγχου από τη μεταφορά δεδομένων.



Σχήμα 2.1: Εννοιολογικό μοντέλο αρχιτεκτονικής Zero trust

Η αρχιτεκτονική διακρίνεται σε δύο βασικά επίπεδα: το **control plane** και το **data plane**. Το control plane είναι υπεύθυνο για τη λήψη αποφάσεων και τη διαχείριση πολιτικών πρόσβασης, ενώ το data plane χρησιμοποιείται για την πραγματική μεταφορά δεδομένων μεταξύ χρηστών και πόρων . Ο διαχωρισμός αυτός διασφαλίζει ότι καμία επικοινωνία δεν πραγματοποιείται χωρίς προηγούμενη έγκριση.

Στον πυρήνα της αρχιτεκτονικής βρίσκονται τρία βασικά λογικά συστατικά:

- **Policy Engine (PE)**: λαμβάνει την τελική απόφαση για το αν θα επιτραπεί ή όχι η πρόσβαση σε έναν πόρο. Η απόφαση βασίζεται σε πολιτικές ασφαλείας και δεδομένα από πολλαπλές πηγές, όπως πληροφορίες απειλών και κατάσταση συσκευών .
- **Policy Administrator (PA)**: υλοποιεί την απόφαση του Policy Engine, δημιουργώντας ή διακόπτοντας τη σύνδεση μεταξύ χρήστη και πόρου .
- **Policy Enforcement Point (PEP)**: λειτουργεί ως σημείο ελέγχου που επιτρέπει, παρακολουθεί ή τερματίζει τη σύνδεση, βάσει των εντολών που λαμβάνει από το Policy Administrator .

Η λειτουργία της αρχιτεκτονικής ακολουθεί συγκεκριμένη ροή. Ένας χρήστης ή μια συσκευή (subject) αιτείται πρόσβαση σε έναν εταιρικό πόρο. Το αίτημα αυτό αξιολογείται από το Policy Engine, το οποίο λαμβάνει υπόψη την ταυτότητα, την κατάσταση της συσκευής και άλλα συμφραζόμενα δεδομένα. Στη συνέχεια, ο Policy Administrator εφαρμόζει την απόφαση ρυθμίζοντας το Policy Enforcement Point, το οποίο είτε επιτρέπει είτε απορρίπτει την επικοινωνία. Η διαδικασία αυτή δεν είναι στατική αλλά επαναλαμβάνεται συνεχώς καθ’ όλη τη διάρκεια της σύνδεσης.

Επιπλέον, η αρχιτεκτονική υποστηρίζεται από εξωτερικές πηγές δεδομένων, όπως συστήματα παρακολούθησης, καταγραφής δραστηριοτήτων και πληροφοριών απειλών, οι οποίες τροφοδοτούν το Policy Engine με δυναμικά δεδομένα για τη λήψη πιο ακριβών αποφάσεων .

Η παραπάνω δομή εξηγεί γιατί στο Zero Trust κανένας χρήστης ή σύστημα δεν θεωρείται εξ ορισμού αξιόπιστος, ακόμα και αν βρίσκεται εντός του δικτύου. Κάθε αίτημα πρόσβασης ελέγχεται δυναμικά, ενισχύοντας σημαντικά την ασφάλεια των πληροφοριακών συστημάτων.

2.3 Τρέχουσες Τεχνολογίες και Τεχνικές

Οι τεχνολογίες που υποστηρίζουν το μοντέλο Zero Trust δεν λειτουργούν απομονωμένα, αλλά εντάσσονται σε μία ενιαία αρχιτεκτονική που υλοποιεί

τις αρχές της συνεχούς επαλήθευσης, της ελάχιστης πρόσβασης και της υπόθεσης παραβίασης. Οι ακόλουθες τεχνολογίες αποτελούν βασικά δομικά στοιχεία της σύγχρονης υλοποίησης Zero Trust.

Identity and Access Management (IAM)
Η διαχείριση ταυτότητας και πρόσβασης αποτελεί τον πυρήνα της αρχιτεκτονικής Zero Trust, καθώς η ταυτότητα αντικαθιστά την τοποθεσία ως βασικό κριτήριο εμπιστοσύνης. Τα συστήματα IAM επιτρέπουν την ταυτοποίηση και τον έλεγχο χρηστών και συσκευών, παρέχοντας μηχανισμούς αυθεντικοποίησης και εξουσιοδότησης. Στο πλαίσιο αυτό, τεχνικές όπως η πολυπαραγοντική αυθεντικοποίηση (MFA), η ενιαία σύνδεση (Single Sign-On - SSO) και ο έλεγχος πρόσβασης βάσει ρόλων (Role-Based Access Control - RBAC) συμβάλλουν στη βελτίωση της ασφάλειας και στη μείωση των κινδύνων που σχετίζονται με την ταυτότητα.

Multi-Factor Authentication (MFA)
Η πολυπαραγοντική αυθεντικοποίηση ενισχύει τη διαδικασία επαλήθευσης απαιτώντας περισσότερους από έναν παράγοντες ταυτοποίησης, όπως κωδικούς πρόσβασης, βιομετρικά δεδομένα ή φυσικές συσκευές. Η MFA αποτελεί βασική υλοποίηση της αρχής “verify explicitly”, μειώνοντας σημαντικά την πιθανότητα μη εξουσιοδοτημένης πρόσβασης ακόμη και σε περιπτώσεις υποκλοπής διαπιστευτηρίων.

Zero Trust Network Access (ZTNA)
Το ZTNA αντικαθιστά τα παραδοσιακά VPN, παρέχοντας πρόσβαση μόνο σε συγκεκριμένους πόρους αντί για ολόκληρο το δίκτυο. Σύμφωνα με την Cloudflare, κάθε αίτημα πρόσβασης αξιολογείται δυναμικά με βάση την ταυτότητα και τα συμφραζόμενα δεδομένα. Με τον τρόπο αυτό περιορίζεται η επιφάνεια επίθεσης και αποτρέπεται η ανεξέλεγκτη πρόσβαση σε εσωτερικά συστήματα.

Microsegmentation
Η μικροτμηματοποίηση διαχωρίζει το δίκτυο σε μικρότερες, απομονωμένες ζώνες, επιτρέποντας την εφαρμογή λεπτομερών πολιτικών πρόσβασης. Η τεχνική αυτή υποστηρίζει την αρχή του least privilege και περιορίζει την πλευρική μετακίνηση (lateral movement) επιτιθέμενων εντός του δικτύου. Σύμφωνα με την Fortinet, η microsegmentation ενισχύει την απομόνωση κρίσιμων πόρων και μειώνει τον κίνδυνο εξάπλωσης επιθέσεων.

Endpoint Security
Η ασφάλεια τερματικών συσκευών επικεντρώνεται στην προστασία και αξιολόγηση των συσκευών που αποκτούν πρόσβαση σε επιχειρησιακούς πόρους. Περιλαμβάνει μηχανισμούς ελέγχου της κατάστασης της συσκευής (device posture), τακτικές ενημερώσεις και δυνατότητες ανίχνευσης απειλών. Σύμφωνα με την CrowdStrike, η συνεχής παρακολούθηση των endpoints αποτελεί κρίσιμο παράγοντα για την έγκαιρη ανίχνευση και περιορισμό επιθέσεων.

Οι παραπάνω τεχνολογίες λειτουργούν συνδυαστικά, επιτρέποντας την υλοποίηση ενός δυναμικού και πολυεπίπεδου μοντέλου ασφάλειας, το οποίο ανταποκρίνεται στις απαιτήσεις των σύγχρονων επιχειρησιακών πληροφοριακών συστημάτων.

2.4 Υλοποίηση Zero Trust σε Σύγχρονα Περιβάλλοντα

Η υλοποίηση του μοντέλου Zero Trust στα σύγχρονα επιχειρησιακά πληροφοριακά συστήματα συνδέεται άμεσα με τη μετάβαση σε cloud και κατανεμημένες υποδομές. Σε αντίθεση με τα παραδοσιακά μοντέλα που βασίζονται σε σαφώς οριοθετημένα δίκτυα, τα σύγχρονα περιβάλλοντα χαρακτηρίζονται από δυναμική πρόσβαση σε πόρους από διαφορετικές τοποθεσίες και συσκευές. Σύμφωνα με την προσέγγιση της Microsoft, η ασφάλεια μετατοπίζεται από το δίκτυο προς την ταυτότητα, με κάθε αίτημα πρόσβασης να αξιολογείται ανεξάρτητα από τη φυσική του προέλευση.

Στο πλαίσιο αυτό, οι επιχειρησιακές εφαρμογές, όπως συστήματα ERP, CRM και υπηρεσίες SaaS, ενσωματώνονται σε αρχιτεκτονικές που βασίζονται στη διαχείριση ταυτότητας και στον έλεγχο πρόσβασης σε επίπεδο πόρου. Η χρήση τεχνολογιών όπως IAM και ZTNA επιτρέπει την ασφαλή πρόσβαση σε εφαρμογές χωρίς την ανάγκη πλήρους σύνδεσης στο εταιρικό δίκτυο, μειώνοντας σημαντικά την επιφάνεια επίθεσης. Παράλληλα, η εφαρμογή πολιτικών πρόσβασης προσαρμόζεται δυναμικά με βάση το προφίλ του χρήστη και τα συμφραζόμενα δεδομένα.

Η εξάπλωση της απομακρυσμένης εργασίας καθιστά κρίσιμη την ασφαλή διαχείριση χρηστών και συσκευών εκτός εταιρικού δικτύου. Στο μοντέλο

Zero Trust, κάθε συσκευή αξιολογείται συνεχώς ως προς την κατάστασή της (device posture), ενώ η πρόσβαση σε πόρους επιτρέπεται μόνο εφόσον πληρούνται συγκεκριμένα κριτήρια ασφάλειας. Η προσέγγιση αυτή διασφαλίζει ότι ακόμη και σε μη αξιόπιστα δίκτυα, η πρόσβαση παραμένει ελεγχόμενη και περιορισμένη.

Πρακτικές υλοποιήσεις του μοντέλου Zero Trust έχουν ήδη εφαρμοστεί από μεγάλους οργανισμούς. Η Google, μέσω της αρχιτεκτονικής BeyondCorp, εισήγαγε ένα μοντέλο πρόσβασης χωρίς VPN, όπου η ταυτότητα και το πλαίσιο πρόσβασης καθορίζουν την επιτρεπτή επικοινωνία. Αντίστοιχα, λύσεις της Cloudflare υλοποιούν Zero Trust Network Access για την ασφαλή σύνδεση χρηστών με εφαρμογές, επιβεβαιώνοντας ότι το μοντέλο Zero Trust εφαρμόζεται ήδη σε πραγματικά επιχειρησιακά περιβάλλοντα.

Η υλοποίηση του Zero Trust σε σύγχρονα περιβάλλοντα δεν αποτελεί μία μεμονωμένη τεχνολογία, αλλά ένα ολοκληρωμένο πλαίσιο που συνδυάζει πολλαπλά εργαλεία και πρακτικές, προσαρμοσμένο στις ανάγκες των σύγχρονων επιχειρήσεων.

3. Παρουσίαση και Αξιολόγηση του Μοντέλου Zero Trust

3.1 Σύγκριση Παραδοσιακού Μοντέλου και Zero Trust

Το παραδοσιακό μοντέλο περιμετρικής ασφάλειας βασίζεται στη διάκριση μεταξύ ενός έμπιστου εσωτερικού δικτύου και ενός μη έμπιστου εξωτερικού περιβάλλοντος. Η πρόσβαση ελέγχεται κυρίως στο σημείο εισόδου, μέσω μηχανισμών όπως firewalls, και αφού ένας χρήστης ή σύστημα αποκτήσει πρόσβαση, θεωρείται αξιόπιστο εντός του δικτύου. Η προσέγγιση αυτή στηρίζεται σε στατικά όρια δικτύου και σε μία έμμεση εμπιστοσύνη προς τις εσωτερικές οντότητες, γεγονός που την καθιστά ευάλωτη σε σύγχρονες απειλές.

Αντίθετα, το μοντέλο Zero Trust απορρίπτει την έννοια της προκαθορισμένης εμπιστοσύνης και υιοθετεί την αρχή ότι καμία οντότητα δεν θεωρείται αξιόπιστη εκ προοιμίου. Κάθε αίτημα πρόσβασης επαληθεύεται δυναμικά με βάση πολλαπλούς παράγοντες, όπως η ταυτότητα, η κατάσταση της συσκευής και το περιβάλλον πρόσβασης. Η εμπιστοσύνη δεν βασίζεται στη θέση εντός του δικτύου, αλλά σε συνεχή αξιολόγηση κινδύνου.

Μία βασική διαφορά μεταξύ των δύο προσεγγίσεων αφορά τον τρόπο αντιμετώπισης των απειλών. Στο παραδοσιακό μοντέλο, η κύρια έμφαση δίνεται στην αποτροπή εξωτερικών επιθέσεων, με την υπόθεση ότι το εσωτερικό δίκτυο είναι ασφαλές. Ωστόσο οι σύγχρονες απειλές προέρχονται τόσο από εξωτερικούς όσο και από εσωτερικούς παράγοντες. Το Zero Trust λαμβάνει υπόψη αυτή την πραγματικότητα, εφαρμόζοντας συνεχή έλεγχο και εντός του δικτύου, περιορίζοντας την πιθανότητα πλευρικής μετακίνησης επιτιθέμενων.

Επιπλέον, το παραδοσιακό μοντέλο βασίζεται σε κεντρικά σημεία ελέγχου, γεγονός που το καθιστά λιγότερο ευέλικτο σε περιβάλλοντα cloud και απομακρυσμένης εργασίας. Αντίθετα, το Zero Trust σχεδιάστηκε για κατανεμημένα περιβάλλοντα, όπου οι χρήστες και οι πόροι βρίσκονται εκτός των παραδοσιακών δικτυακών ορίων. Η προσέγγιση αυτή επιτρέπει πιο ακριβή και προσαρμοστικό έλεγχο πρόσβασης, ανεξαρτήτως τοποθεσίας.

Συνολικά, το παραδοσιακό μοντέλο βασίζεται σε στατική εμπιστοσύνη και οριοθετημένα δίκτυα, ενώ το Zero Trust υιοθετεί μία δυναμική και συνεχώς επαληθευόμενη προσέγγιση ασφάλειας, προσαρμοσμένη στις απαιτήσεις των σύγχρονων επιχειρησιακών πληροφοριακών συστημάτων.

3.2 Σύγκριση Τεχνολογιών και Μηχανισμών

Η μετάβαση από το παραδοσιακό μοντέλο ασφάλειας στο Zero Trust δεν αφορά μόνο αλλαγή φιλοσοφίας, αλλά και αντικατάσταση ή αναδιαμόρφωση βασικών τεχνολογιών και μηχανισμών πρόσβασης.

VPN vs Zero Trust Network Access (ZTNA)
Τα παραδοσιακά Virtual Private Networks (VPN) παρέχουν στους χρήστες πρόσβαση σε ολόκληρο το εταιρικό δίκτυο μετά την επιτυχή αυθεντικοποίηση. Η προσέγγιση αυτή βασίζεται στην έννοια της δικτυακής εμπιστοσύνης, καθώς ο χρήστης θεωρείται αξιόπιστος μετά τη σύνδεση. Αντίθετα, το Zero Trust Network Access (ZTNA) παρέχει πρόσβαση μόνο σε συγκεκριμένες εφαρμογές ή πόρους, χωρίς να εκθέτει το σύνολο του δικτύου. Το ZTNA εφαρμόζει έλεγχο πρόσβασης σε επίπεδο εφαρμογής και αξιολογεί δυναμικά κάθε αίτημα, μειώνοντας σημαντικά την επιφάνεια επίθεσης (Cloudflare). Αντίστοιχα, η προσέγγιση της Microsoft επιβεβαιώνει ότι η μετάβαση από VPN σε ZTNA αποτελεί βασικό στοιχείο της υλοποίησης Zero Trust σε επιχειρησιακά περιβάλλοντα.

Perimeter Firewall vs Microsegmentation
Στο παραδοσιακό μοντέλο, η ασφάλεια βασίζεται σε κεντρικά σημεία ελέγχου, όπως τα firewalls, τα οποία προστατεύουν το δίκτυο σε επίπεδο περιμέτρου. Η προσέγγιση αυτή επιτρέπει την ελεύθερη επικοινωνία εντός του εσωτερικού δικτύου μετά την αρχική πρόσβαση. Αντίθετα, η microsegmentation διαχωρίζει το δίκτυο σε μικρότερες, απομονωμένες ζώνες, επιτρέποντας την εφαρμογή λεπτομερών πολιτικών πρόσβασης μεταξύ πόρων. Η κατανεμημένη αυτή προσέγγιση ελέγχου ευθυγραμμίζεται με την αρχιτεκτονική Zero Trust, ενώ η microsegmentation περιορίζει αποτελεσματικά την πλευρική μετακίνηση επιτιθέμενων εντός του δικτύου.

Implicit Trust vs Continuous Authentication
Το παραδοσιακό μοντέλο βασίζεται στην έννοια της έμμεσης εμπιστοσύνης (implicit trust), όπου η αυθεντικοποίηση πραγματοποιείται κυρίως κατά την είσοδο στο σύστημα και η περαιτέρω δραστηριότητα θεωρείται αξιόπιστη. Αντίθετα, το Zero Trust υιοθετεί τη συνεχή επαλήθευση (continuous authentication), όπου κάθε αίτημα πρόσβασης επανεξετάζεται δυναμικά. Η αρχή “verify explicitly” επιβάλλει συνεχή έλεγχο ταυτότητας και συμφραζομένων δεδομένων. Παράλληλα, η Google, μέσω της αρχιτεκτονικής BeyondCorp, εφαρμόζει ένα μοντέλο στο οποίο η πρόσβαση βασίζεται αποκλειστικά στην ταυτότητα και το πλαίσιο, χωρίς να απαιτείται εμπιστοσύνη στο δίκτυο.

Συνολικά, οι τεχνολογικές αυτές μεταβολές αντικατοπτρίζουν τη μετάβαση από ένα στατικό και περιμετρικό μοντέλο ασφάλειας σε ένα δυναμικό και κατανεμημένο μοντέλο, όπου η πρόσβαση ελέγχεται συνεχώς και σε πολλαπλά επίπεδα.

3.3 Αξιολόγηση σε Επιχειρησιακά Πληροφοριακά Συστήματα

Ασφάλεια δεδομένων
Το μοντέλο περιορίζει δραστικά την πρόσβαση μέσω least privilege και συνεχούς ελέγχου. Η πρόσβαση δίνεται μόνο όταν απαιτείται και επανεξετάζεται δυναμικά σε κάθε αίτημα . Αυτό μειώνει σημαντικά την πιθανότητα εσωτερικής διάδοσης επιθέσεων (lateral movement) .

Υποστήριξη σύγχρονων υποδομών (cloud, remote)
Τα σύγχρονα πληροφοριακά συστήματα δεν έχουν σαφή περίμετρο. Το Zero Trust αντιμετωπίζει όλα τα περιβάλλοντα ως μη αξιόπιστα, επιτρέποντας ασφαλή πρόσβαση ανεξαρτήτως τοποθεσίας.

Διαχείριση πρόσβασης
Η αρχιτεκτονική βασίζεται σε κεντρικό έλεγχο μέσω μηχανισμών όπως Policy Decision Point (PDP) και Policy Enforcement Point (PEP), όπου κάθε αίτημα αξιολογείται πριν εγκριθεί . Η πρόσβαση δεν θεωρείται δεδομένη αλλά επαληθεύεται συνεχώς.

Λειτουργική πολυπλοκότητα
Η εφαρμογή Zero Trust απαιτεί ανασχεδιασμό αρχιτεκτονικής και ενσωμάτωση πολλαπλών μηχανισμών (identity, monitoring, policies). Δεν αποτελεί μεμονωμένη τεχνολογία αλλά σύνολο αρχών που εφαρμόζονται σταδιακά.

3.4 Πλεονεκτήματα και Μειονεκτήματα Zero Trust

Η συνολική αξιολόγηση του μοντέλου Zero Trust προκύπτει από τη σύγκριση με το παραδοσιακό μοντέλο και την εφαρμογή του σε σύγχρονα επιχειρησιακά πληροφοριακά συστήματα.

Πλεονεκτήματα

Ενισχυμένη ασφάλεια δεδομένων
Το Zero Trust εφαρμόζει αυστηρό έλεγχο πρόσβασης βάσει της αρχής least privilege, επιτρέποντας πρόσβαση μόνο στους απαραίτητους πόρους. Η συνεχής επαλήθευση περιορίζει την πιθανότητα μη εξουσιοδοτημένης πρόσβασης και μειώνει τον κίνδυνο διαρροής δεδομένων .

Περιορισμός πλευρικής μετακίνησης επιθέσεων
Σε αντίθεση με το παραδοσιακό μοντέλο, όπου η πρόσβαση εντός του δικτύου είναι ευρεία, το Zero Trust περιορίζει την επικοινωνία μεταξύ συστημάτων. Αυτό μειώνει σημαντικά τη δυνατότητα ενός επιτιθέμενου να κινηθεί εντός του δικτύου μετά από αρχική παραβίαση .

Καταλληλότητα για σύγχρονα περιβάλλοντα
Το μοντέλο υποστηρίζει αποτελεσματικά cloud υποδομές, απομακρυσμένη εργασία και χρήση πολλαπλών συσκευών, καθώς δεν βασίζεται σε στατικά δικτυακά όρια αλλά σε ταυτότητα και συμφραζόμενα δεδομένα .

Λεπτομερής και δυναμικός έλεγχος πρόσβασης
Η χρήση μηχανισμών όπως Policy Decision Point (PDP) και Policy Enforcement Point (PEP) επιτρέπει τη λήψη αποφάσεων σε πραγματικό χρόνο για κάθε αίτημα πρόσβασης .

Μειονεκτήματα

Υψηλή πολυπλοκότητα υλοποίησης
Το Zero Trust δεν αποτελεί έτοιμη λύση αλλά σύνολο αρχών που απαιτούν συνδυασμό τεχνολογιών και ανασχεδιασμό της αρχιτεκτονικής ενός οργανισμού .

Σταδιακή και απαιτητική μετάβαση
Η μετάβαση από το παραδοσιακό μοντέλο δεν μπορεί να γίνει άμεσα, αλλά απαιτεί σταδιακή υλοποίηση και προσαρμογή των υφιστάμενων συστημάτων .

Εξάρτηση από σωστή διαχείριση ταυτότητας
Η αποτελεσματικότητα του μοντέλου εξαρτάται από την ακρίβεια και την πληρότητα των δεδομένων ταυτότητας και των πολιτικών πρόσβασης.

Ανεπαρκής διαχείριση μπορεί να οδηγήσει σε λανθασμένες αποφάσεις πρόσβασης.

Αυξημένες απαιτήσεις σε πόρους και διαχείριση
Η συνεχής παρακολούθηση, η επαναξιολόγηση αιτημάτων και η εφαρμογή δυναμικών πολιτικών αυξάνουν τις απαιτήσεις σε υπολογιστικούς πόρους και διοικητική διαχείριση.

Το Zero Trust προσφέρει ένα σαφώς ισχυρότερο πλαίσιο ασφάλειας σε σχέση με το παραδοσιακό μοντέλο, ωστόσο η υιοθέτησή του συνοδεύεται από αυξημένη πολυπλοκότητα και απαιτήσεις υλοποίησης, γεγονός που το καθιστά περισσότερο στρατηγική επιλογή παρά απλή τεχνολογική αναβάθμιση.

4. Μελέτη Περίπτωσης: Εφαρμογή Zero Trust σε Επιχείρηση

4.1 Περιγραφή Σεναρίου Επιχείρησης

Η μελέτη περίπτωσης αφορά μία σύγχρονη επιχείρηση με κατανεμημένη υποδομή και υιοθέτηση cloud υπηρεσιών. Σύμφωνα με το National Institute of Standards and Technology, τα σύγχρονα enterprise περιβάλλοντα χαρακτηρίζονται από αυξημένη πολυπλοκότητα, καθώς περιλαμβάνουν εσωτερικά δίκτυα, απομακρυσμένα γραφεία, χρήστες εκτός εταιρικού δικτύου και υπηρεσίες cloud .

Στο συγκεκριμένο σενάριο, η επιχείρηση διαθέτει κεντρικά γραφεία και απομακρυσμένες εγκαταστάσεις, ενώ οι εργαζόμενοι έχουν τη δυνατότητα πρόσβασης σε εταιρικούς πόρους τόσο από εταιρικές όσο και από προσωπικές συσκευές. Η υποδομή περιλαμβάνει εφαρμογές που φιλοξενούνται σε cloud περιβάλλοντα, καθώς και υπηρεσίες όπως ERP και

συστήματα διαχείρισης δεδομένων, στα οποία απαιτείται ελεγχόμενη πρόσβαση.

Επιπλέον, η επιχείρηση συνεργάζεται με εξωτερικούς χρήστες και παρόχους υπηρεσιών, οι οποίοι χρειάζονται περιορισμένη πρόσβαση σε συγκεκριμένους πόρους. Η διαχείριση αυτής της πρόσβασης αποτελεί σημαντική πρόκληση, καθώς πρέπει να διασφαλιστεί ότι οι εξωτερικοί χρήστες δεν αποκτούν πρόσβαση σε κρίσιμα δεδομένα ή εσωτερικά συστήματα.

Η αυξανόμενη χρήση cloud υπηρεσιών και η ανάγκη για απομακρυσμένη εργασία καθιστούν το παραδοσιακό μοντέλο περιμετρικής ασφάλειας ανεπαρκές, καθώς δεν υπάρχει πλέον σαφώς καθορισμένο όριο δικτύου. Σύμφωνα με το Microsoft, η πρόσβαση στους πόρους πρέπει να βασίζεται στην ταυτότητα και στο πλαίσιο πρόσβασης και όχι στη θέση του χρήστη στο δίκτυο.

Ως αποτέλεσμα, η επιχείρηση αντιμετωπίζει βασικές προκλήσεις:

- διαχείριση πρόσβασης σε κατανεμημένα περιβάλλοντα
- προστασία δεδομένων σε cloud υποδομές
- έλεγχος συσκευών και χρηστών εκτός δικτύου
- ασφαλής συνεργασία με εξωτερικούς χρήστες

Οι προκλήσεις αυτές καθιστούν αναγκαία τη μετάβαση σε μία αρχιτεκτονική Zero Trust, η οποία θα παρουσιαστεί στην επόμενη ενότητα.

4.2 Αρχιτεκτονική Λύσης Zero Trust

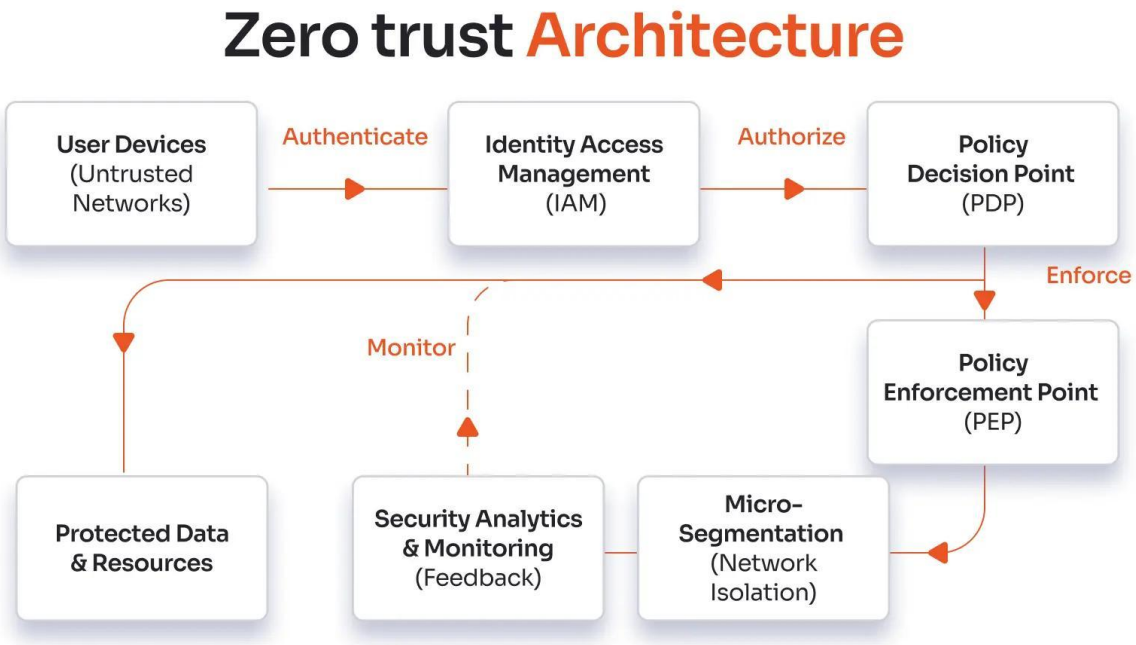
Η υλοποίηση της αρχιτεκτονικής Zero Trust στο περιβάλλον της επιχείρησης βασίζεται σε έναν συνδυασμό μηχανισμών ελέγχου ταυτότητας, πολιτικών πρόσβασης και σημείων επιβολής ελέγχου, σύμφωνα με το μοντέλο που προτείνεται από το National Institute of Standards and Technology. Η αρχιτεκτονική αυτή δεν στηρίζεται σε ένα κεντρικό δίκτυο εμπιστοσύνης, αλλά σε κατανεμημένα σημεία ελέγχου που διασφαλίζουν ότι κάθε αίτημα πρόσβασης αξιολογείται δυναμικά.

Στο προτεινόμενο σενάριο, η αρχιτεκτονική οργανώνεται γύρω από τρία βασικά επίπεδα:

- **Επίπεδο Ταυτότητας (Identity Layer)**: Περιλαμβάνει συστήματα Identity and Access Management (IAM), τα οποία διαχειρίζονται την ταυτότητα χρηστών και συσκευών. Η αυθεντικοποίηση ενισχύεται μέσω μηχανισμών Multi-Factor Authentication (MFA), ενώ εφαρμόζονται πολιτικές conditional access για την αξιολόγηση κάθε αιτήματος με βάση το πλαίσιο πρόσβασης, όπως προτείνεται από την Microsoft.
- **Επίπεδο Ελέγχου Πρόσβασης (Access Layer)**: Η πρόσβαση στους επιχειρησιακούς πόρους πραγματοποιείται μέσω μηχανισμών Zero Trust Network Access (ZTNA), οι οποίοι αντικαθιστούν τα παραδοσιακά VPN. Αντί για πλήρη πρόσβαση στο δίκτυο, οι χρήστες αποκτούν πρόσβαση μόνο σε συγκεκριμένες εφαρμογές ή υπηρεσίες, βάσει των πολιτικών που εφαρμόζονται.
- **Επίπεδο Επιβολής Πολιτικών (Enforcement Layer)**: Το επίπεδο αυτό υλοποιείται μέσω των Policy Enforcement Points (PEPs), τα οποία λειτουργούν ως σημεία ελέγχου μεταξύ χρηστών και πόρων. Τα PEPs λαμβάνουν αποφάσεις από το Policy Decision Point (PDP), το οποίο αποτελείται από τα components Policy Engine και Policy Administrator, όπως ορίζεται στο μοντέλο του NIST .

Η συνολική λειτουργία της αρχιτεκτονικής βασίζεται στη συνεχή ανταλλαγή πληροφοριών μεταξύ των παραπάνω επιπέδων. Τα αιτήματα πρόσβασης αξιολογούνται με βάση δεδομένα που προέρχονται από πολλαπλές πηγές, όπως η ταυτότητα χρήστη, η κατάσταση της συσκευής και το ιστορικό δραστηριότητας. Η απόφαση για την παροχή ή μη πρόσβασης λαμβάνεται δυναμικά και επανεξετάζεται καθ’ όλη τη διάρκεια της σύνδεσης.

Η προσέγγιση αυτή επιτρέπει στην επιχείρηση να εφαρμόσει λεπτομερείς πολιτικές πρόσβασης, περιορίζοντας την έκθεση των πόρων και ενισχύοντας την ασφάλεια σε κατανεμημένα περιβάλλοντα, όπου δεν υπάρχει σαφές όριο δικτύου.



Σχήμα 4.1: Αρχιτεκτονική Zero Trust που απεικονίζει τη ροή ελέγχου πρόσβασης από τις συσκευές χρηστών προς τους επιχειρησιακούς πόρους, μέσω IAM, PDP, PEP καθώς και το συνεχές monitoring και microsegmentation του δικτύου

4.3 Ροή Πρόσβασης (Access Flow)

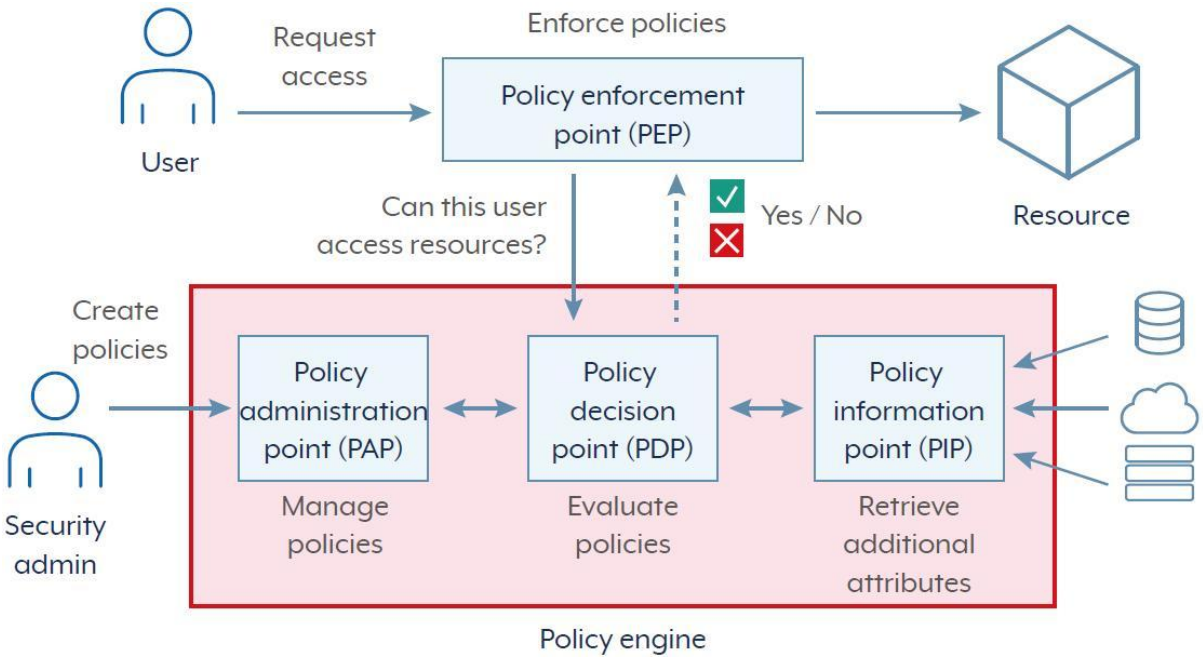
Η ροή πρόσβασης στο μοντέλο Zero Trust βασίζεται σε μία δυναμική και συνεχώς επαναλαμβανόμενη διαδικασία αξιολόγησης, όπου κάθε αίτημα εξετάζεται πριν εγκριθεί. Σε αντίθεση με τα παραδοσιακά μοντέλα, η πρόσβαση δεν θεωρείται δεδομένη μετά την αρχική είσοδο, αλλά επαληθεύεται σε κάθε στάδιο. Η λογική αυτή ευθυγραμμίζεται με το μοντέλο PDP/PEP του National Institute of Standards and Technology και τις πρακτικές υλοποιήσεις Zero Trust που εφαρμόζονται από οργανισμούς όπως η Google και η Cloudflare.

Η διαδικασία πρόσβασης στο σενάριο της επιχείρησης εξελίσσεται ως εξής:

1. **Αίτημα Πρόσβασης (Request)**
   Ο χρήστης, μέσω μιας συσκευής (εταιρικής ή προσωπικής), επιχειρεί να αποκτήσει πρόσβαση σε έναν επιχειρησιακό πόρο, όπως μια εφαρμογή ή μια βάση δεδομένων.

2. **Έλεγχος Ταυτότητας (Authentication)**
   Το σύστημα Identity and Access Management (IAM) επαληθεύει την ταυτότητα του χρήστη μέσω μηχανισμών όπως Multi-Factor Authentication (MFA). Η διαδικασία αυτή διασφαλίζει ότι ο χρήστης είναι αυτός που δηλώνει.
3. **Έλεγχος Συσκευής και Συμφραζομένων (Device & Context Check)**
   Εξετάζεται η κατάσταση της συσκευής (device posture), όπως ενημερώσεις λογισμικού, επίπεδο ασφάλειας και πιθανές ενδείξεις παραβίασης. Παράλληλα, λαμβάνονται υπόψη συμφραζόμενα δεδομένα, όπως τοποθεσία, ώρα πρόσβασης και συμπεριφορά χρήστη.
4. **Λήψη Απόφασης (Policy Decision)**
   Το Policy Decision Point (PDP) αξιολογεί το αίτημα με βάση προκαθορισμένες πολιτικές ασφάλειας και τα διαθέσιμα δεδομένα. Η απόφαση μπορεί να είναι:
   - **Έγκριση (Allow)**, εφόσον πληρούνται όλα τα κριτήρια
   - **Απόρριψη (Deny)**, εάν εντοπιστεί κίνδυνος ή μη συμμόρφωση
5. **Επιβολή Απόφασης (Enforcement)**
   Το Policy Enforcement Point (PEP) εφαρμόζει την απόφαση του PDP, επιτρέποντας ή απορρίπτοντας την πρόσβαση στον πόρο.
6. **Συνεχής Παρακολούθηση (Continuous Monitoring)**
   Καθ' όλη τη διάρκεια της σύνδεσης, το σύστημα παρακολουθεί τη δραστηριότητα του χρήστη και της συσκευής. Εάν εντοπιστούν ανωμαλίες, η πρόσβαση μπορεί να επαναξιολογηθεί ή να διακοπεί.

Η προσέγγιση αυτή αντικατοπτρίζει την πρακτική που εφαρμόζεται σε μοντέλα όπως το BeyondCorp της Google, όπου η πρόσβαση βασίζεται αποκλειστικά στην ταυτότητα και στο πλαίσιο πρόσβασης, χωρίς εξάρτηση από το δίκτυο. Παράλληλα, σύμφωνα με την Cloudflare, κάθε αίτημα αντιμετωπίζεται ως ανεξάρτητο και αξιολογείται δυναμικά, μειώνοντας την πιθανότητα μη εξουσιοδοτημένης πρόσβασης.



Σχήμα 4.2: Ροή πρόσβασης στο μοντέλο Zero Trust, όπου κάθε αίτημα αξιολογείται διαδοχικά μέσω ελέγχου ταυτότητας, κατάστασης συσκευής και πολιτικών ασφάλειας, οδηγώντας σε απόφαση έγκρισης ή απόρριψης

4.4 Αξιολόγηση της Λύσης

Η αξιολόγηση της προτεινόμενης αρχιτεκτονικής Zero Trust βασίζεται στην εφαρμογή της στο συγκεκριμένο επιχειρησιακό σενάριο και στην ανάλυση των επιπτώσεών της σε σχέση με το παραδοσιακό μοντέλο ασφάλειας. Η προσέγγιση αυτή ευθυγραμμίζεται με τις κατευθύνσεις του National Institute of Standards and Technology, σύμφωνα με τις οποίες το Zero Trust αποτελεί μία στρατηγική μετάβασης και όχι μία άμεση τεχνολογική αντικατάσταση.

Στο εξεταζόμενο περιβάλλον, η εφαρμογή του Zero Trust ενισχύει σημαντικά την ασφάλεια των πληροφοριακών συστημάτων. Η χρήση μηχανισμών όπως IAM, MFA και ZTNA επιτρέπει τον αυστηρό έλεγχο πρόσβασης σε επίπεδο χρήστη και συσκευής, περιορίζοντας την έκθεση των πόρων. Σε αντίθεση με το παραδοσιακό μοντέλο, όπου η πρόσβαση εντός του δικτύου είναι ευρεία μετά την αρχική είσοδο, το Zero Trust

διασφαλίζει ότι κάθε αίτημα αξιολογείται ανεξάρτητα, μειώνοντας την πιθανότητα πλευρικής μετακίνησης επιτιθέμενων εντός του συστήματος.

Παράλληλα, η αρχιτεκτονική αυτή προσαρμόζεται αποτελεσματικά στις απαιτήσεις των σύγχρονων επιχειρησιακών περιβαλλόντων. Η υποστήριξη απομακρυσμένης πρόσβασης και cloud υπηρεσιών επιτρέπει στην επιχείρηση να λειτουργεί χωρίς την ανάγκη ενός αυστηρά οριοθετημένου δικτύου. Σύμφωνα με την Microsoft, η μετατόπιση της ασφάλειας προς την ταυτότητα και τα συμφραζόμενα δεδομένα αποτελεί βασικό παράγοντα επιτυχίας σε περιβάλλοντα με distributed υποδομές.

Ωστόσο, η υλοποίηση της λύσης συνοδεύεται από σημαντικές προκλήσεις. Η μετάβαση απαιτεί ανασχεδιασμό της υπάρχουσας αρχιτεκτονικής, ενσωμάτωση πολλαπλών τεχνολογιών και ανάπτυξη πολιτικών πρόσβασης που πρέπει να είναι ακριβείς και δυναμικά προσαρμοζόμενες. Επιπλέον, η εξάρτηση από συστήματα διαχείρισης ταυτότητας αυξάνει την πολυπλοκότητα της διαχείρισης και δημιουργεί νέες απαιτήσεις σε επίπεδο παρακολούθησης και συντήρησης.

Συνολικά, στο πλαίσιο του συγκεκριμένου σεναρίου, το Zero Trust αποδεικνύεται καταλληλότερο για την προστασία σύγχρονων επιχειρησιακών πληροφοριακών συστημάτων σε σχέση με το παραδοσιακό μοντέλο. Παρότι η υλοποίησή του είναι πιο απαιτητική, η δυνατότητα συνεχούς ελέγχου, η προσαρμοστικότητα και η ενισχυμένη ασφάλεια που προσφέρει το καθιστούν μία αποτελεσματική στρατηγική για περιβάλλοντα με αυξημένη πολυπλοκότητα και διασυνδεσιμότητα.

5. Μελλοντικές Βελτιώσεις και Κατευθύνσεις

5.1 Ενσωμάτωση Τεχνητής Νοημοσύνης και Αυτοματισμού

Η εξέλιξη του μοντέλου Zero Trust συνδέεται άμεσα με την ενσωμάτωση τεχνολογιών Τεχνητής Νοημοσύνης (AI) και Μηχανικής Μάθησης (ML), οι οποίες επιτρέπουν τη δυναμική και αυτοματοποιημένη διαχείριση της

ασφάλειας. Σύμφωνα με το National Institute of Standards and Technology, η αρχιτεκτονική Zero Trust βασίζεται σε συνεχή παρακολούθηση και συλλογή δεδομένων, τα οποία μπορούν να αξιοποιηθούν για τη βελτίωση των πολιτικών πρόσβασης και την ενίσχυση της συνολικής ασφάλειας.

Ένα βασικό πεδίο εφαρμογής είναι η **ανάλυση συμπεριφοράς χρηστών και οντοτήτων (User and Entity Behavior Analytics – UEBA)**. Μέσω τεχνικών ML, τα συστήματα μπορούν να δημιουργούν πρότυπα φυσιολογικής συμπεριφοράς και να εντοπίζουν αποκλίσεις που ενδέχεται να υποδηλώνουν κακόβουλη δραστηριότητα. Η προσέγγιση αυτή επιτρέπει την έγκαιρη ανίχνευση επιθέσεων που δεν βασίζονται σε γνωστά signatures, αλλά σε ανωμαλίες στη συμπεριφορά.

Παράλληλα, η χρήση AI επιτρέπει τη **δυναμική προσαρμογή των πολιτικών πρόσβασης**. Σύμφωνα με την προσέγγιση της Microsoft, τα σύγχρονα συστήματα Zero Trust αξιολογούν τον κίνδυνο σε πραγματικό χρόνο, λαμβάνοντας υπόψη παράγοντες όπως η ταυτότητα χρήστη, η κατάσταση της συσκευής και το ιστορικό δραστηριότητας. Με βάση αυτή την αξιολόγηση, οι πολιτικές μπορούν να τροποποιούνται δυναμικά, επιτρέποντας ή περιορίζοντας την πρόσβαση χωρίς ανθρώπινη παρέμβαση.

Επιπλέον, η ενσωμάτωση AI οδηγεί σε **αυτοματοποιημένη απόκριση σε απειλές (automated threat response)**. Σύμφωνα με την CrowdStrike, τα σύγχρονα συστήματα endpoint security χρησιμοποιούν τεχνικές ανάλυσης μεγάλων όγκων δεδομένων για την ανίχνευση και άμεση αντιμετώπιση επιθέσεων. Σε ένα περιβάλλον Zero Trust, αυτό μεταφράζεται σε αυτόματες ενέργειες όπως η απομόνωση μιας συσκευής, η επαναφορά δικαιωμάτων πρόσβασης ή η απαίτηση εκ νέου αυθεντικοποίησης.

Η ενσωμάτωση αυτών των τεχνολογιών μετατρέπει το Zero Trust από ένα στατικό μοντέλο ελέγχου πρόσβασης σε ένα δυναμικό και προσαρμοστικό σύστημα ασφάλειας, το οποίο μπορεί να ανταποκρίνεται σε πραγματικό χρόνο στις μεταβαλλόμενες απειλές και συνθήκες λειτουργίας.

5.2 Μετάβαση σε Passwordless Authentication

Η μετάβαση σε μεθόδους αυθεντικοποίησης χωρίς χρήση κωδικών πρόσβασης αποτελεί μία από τις βασικές κατευθύνσεις εξέλιξης του μοντέλου Zero Trust. Οι παραδοσιακοί κωδικοί πρόσβασης αποτελούν μία από τις κύριες αιτίες παραβιάσεων, λόγω πρακτικών όπως η επαναχρησιμοποίηση, η αδύναμη σύνθεση και οι επιθέσεις phishing. Η αντικατάστασή τους με πιο ισχυρούς μηχανισμούς αυθεντικοποίησης ενισχύει σημαντικά την ασφάλεια των πληροφοριακών συστημάτων.

Σύμφωνα με την προσέγγιση της Microsoft, το passwordless authentication βασίζεται σε εναλλακτικούς παράγοντες ταυτοποίησης, όπως βιομετρικά χαρακτηριστικά (δακτυλικό αποτύπωμα, αναγνώριση προσώπου) και συσκευές εμπιστοσύνης. Οι μέθοδοι αυτές μειώνουν την εξάρτηση από μυστικά που μπορούν να υποκλαπούν, μετατοπίζοντας την αυθεντικοποίηση σε στοιχεία που σχετίζονται άμεσα με τον χρήστη ή τη συσκευή.

Ένα βασικό πρότυπο για την υλοποίηση passwordless authentication είναι το FIDO2, το οποίο αναπτύσσεται από την FIDO Alliance. Το πρότυπο αυτό χρησιμοποιεί **hardware security keys** και κρυπτογραφικούς μηχανισμούς δημόσιου/ιδιωτικού κλειδιού, επιτρέποντας την ασφαλή αυθεντικοποίηση χωρίς μετάδοση ή αποθήκευση κωδικών πρόσβασης. Οι συσκευές αυτές μπορούν να λειτουργούν είτε αυτόνομα είτε σε συνδυασμό με βιομετρικά δεδομένα, προσφέροντας υψηλό επίπεδο ασφάλειας.

Η υιοθέτηση passwordless authentication ενισχύει άμεσα τις αρχές του Zero Trust, καθώς:

- μειώνει την πιθανότητα υποκλοπής διαπιστευτηρίων
- ενισχύει τη διαδικασία επαλήθευσης ταυτότητας
- υποστηρίζει την ασφαλή πρόσβαση σε κατανεμημένα περιβάλλοντα

Παράλληλα, βελτιώνει και την εμπειρία χρήστη, καθώς απλοποιεί τη διαδικασία σύνδεσης και μειώνει την ανάγκη διαχείρισης πολλαπλών κωδικών. Ως αποτέλεσμα, η μετάβαση σε passwordless μηχανισμούς αποτελεί κρίσιμο βήμα για την εξέλιξη των σύγχρονων αρχιτεκτονικών ασφάλειας.

5.3 Εξέλιξη Συνεχούς Επαλήθευσης (Continuous Authentication)

Η συνεχής επαλήθευση αποτελεί εξέλιξη της παραδοσιακής αυθεντικοποίησης, μετατοπίζοντας τον έλεγχο από ένα αρχικό στάδιο σύνδεσης σε μία διαρκή διαδικασία αξιολόγησης κατά τη διάρκεια της πρόσβασης. Στο πλαίσιο του Zero Trust, η εμπιστοσύνη δεν αποδίδεται μετά την είσοδο στο σύστημα, αλλά επανεκτιμάται συνεχώς με βάση δυναμικά δεδομένα.

Σύμφωνα με την προσέγγιση της Google μέσω της αρχιτεκτονικής BeyondCorp, η πρόσβαση στους πόρους δεν βασίζεται σε συνεδρίες (sessions) ή στη θέση του χρήστη στο δίκτυο, αλλά σε συμφραζόμενα στοιχεία που αξιολογούνται σε πραγματικό χρόνο. Αυτό σημαίνει ότι κάθε αίτημα αντιμετωπίζεται ως ανεξάρτητο, ακόμη και αν προέρχεται από ήδη αυθεντικοποιημένο χρήστη.

Κεντρικό ρόλο σε αυτή την εξέλιξη διαδραματίζει το **real-time risk scoring**, όπου κάθε αίτημα πρόσβασης συνοδεύεται από μία δυναμική εκτίμηση κινδύνου. Η εκτίμηση αυτή βασίζεται σε πολλαπλούς παράγοντες, όπως:

- η ταυτότητα του χρήστη
- η κατάσταση της συσκευής
- η τοποθεσία πρόσβασης
- το ιστορικό συμπεριφοράς

Η Microsoft υλοποιεί αυτή την προσέγγιση μέσω μηχανισμών conditional access, οι οποίοι επιτρέπουν την εφαρμογή πολιτικών που προσαρμόζονται δυναμικά με βάση το επίπεδο κινδύνου. Για παράδειγμα, ένα αίτημα από άγνωστη τοποθεσία μπορεί να απαιτεί επιπλέον αυθεντικοποίηση, ενώ ένα αίτημα υψηλού κινδύνου μπορεί να απορρίπτεται πλήρως.

Επιπλέον, η συνεχής επαλήθευση αξιοποιεί **behavioral signals**, δηλαδή δεδομένα που προκύπτουν από τη συμπεριφορά χρήστη και συσκευής. Η ανάλυση αυτών των σημάτων επιτρέπει τον εντοπισμό ανωμαλιών, όπως ασυνήθιστες ώρες πρόσβασης ή απότομες αλλαγές στη δραστηριότητα, οδηγώντας σε άμεση επαναξιολόγηση της πρόσβασης.

Η εξέλιξη αυτή μετατρέπει το Zero Trust σε ένα πλήρως δυναμικό σύστημα ελέγχου, όπου η πρόσβαση δεν είναι στατική αλλά προσαρμόζεται συνεχώς στις συνθήκες λειτουργίας. Με τον τρόπο αυτό, ενισχύεται η ικανότητα των επιχειρησιακών πληροφοριακών συστημάτων να ανιχνεύουν και να αποτρέπουν επιθέσεις σε πραγματικό χρόνο, ακόμη και όταν αυτές προέρχονται από ήδη πιστοποιημένους χρήστες.

5.4 Αυτοματοποιημένη και Προσαρμοστική Αρχιτεκτονική Ασφάλειας

Η εξέλιξη του Zero Trust οδηγεί σε αρχιτεκτονικές ασφάλειας που λειτουργούν ολοένα και πιο αυτοματοποιημένα, μειώνοντας την ανάγκη ανθρώπινης παρέμβασης στη λήψη αποφάσεων. Στο πλαίσιο αυτό, η ασφάλεια μετατρέπεται από στατική διαδικασία διαχείρισης πολιτικών σε δυναμικό σύστημα που προσαρμόζεται συνεχώς στις συνθήκες λειτουργίας.

Σύμφωνα με το National Institute of Standards and Technology, η αρχιτεκτονική Zero Trust βασίζεται σε μηχανισμούς όπως τα Policy Engines, τα οποία λαμβάνουν αποφάσεις πρόσβασης με βάση προκαθορισμένες πολιτικές και δεδομένα που συλλέγονται σε πραγματικό χρόνο. Η αυτοματοποίηση αυτών των διαδικασιών επιτρέπει την άμεση εφαρμογή πολιτικών χωρίς καθυστερήσεις, ενισχύοντας την αποτελεσματικότητα του συστήματος.

Ένα βασικό στοιχείο αυτής της προσέγγισης είναι το **policy automation**, όπου οι κανόνες πρόσβασης δημιουργούνται, ενημερώνονται και εφαρμόζονται δυναμικά. Οι πολιτικές δεν είναι στατικές, αλλά προσαρμόζονται με βάση δεδομένα όπως αλλαγές στη συμπεριφορά χρηστών, νέες απειλές ή μεταβολές στην υποδομή του οργανισμού.

Παράλληλα, η ενσωμάτωση με συστήματα όπως **SIEM (Security Information and Event Management)** και **XDR (Extended Detection and Response)** επιτρέπει τη συλλογή και ανάλυση μεγάλου όγκου δεδομένων από διαφορετικές πηγές. Τα δεδομένα αυτά χρησιμοποιούνται για την

ενίσχυση της λήψης αποφάσεων και τη βελτίωση των πολιτικών ασφάλειας, δημιουργώντας ένα ενοποιημένο περιβάλλον παρακολούθησης και απόκρισης.

Σύμφωνα με την προσέγγιση της Cloudflare, τα σύγχρονα συστήματα Zero Trust εφαρμόζουν αυτοματοποιημένο έλεγχο πρόσβασης μέσω μηχανισμών όπως το ZTNA, όπου κάθε αίτημα αξιολογείται και επιβάλλεται σε πραγματικό χρόνο. Η διαδικασία αυτή πραγματοποιείται χωρίς ανθρώπινη παρέμβαση, επιτρέποντας την άμεση απόκριση σε απειλές και την αποτροπή μη εξουσιοδοτημένης πρόσβασης.

Η υιοθέτηση μιας αυτοματοποιημένης και προσαρμοστικής αρχιτεκτονικής ασφάλειας μετατρέπει το Zero Trust σε ένα πλήρως δυναμικό σύστημα, ικανό να ανταποκρίνεται σε πραγματικό χρόνο στις μεταβαλλόμενες απαιτήσεις και απειλές. Με τον τρόπο αυτό, ενισχύεται η ανθεκτικότητα των επιχειρησιακών πληροφοριακών συστημάτων και βελτιώνεται η συνολική αποτελεσματικότητα της ασφάλειας.

6. Συμπεράσματα

Η παρούσα εργασία ανέδειξε τη μετάβαση από το παραδοσιακό μοντέλο περιμετρικής ασφάλειας σε μία νέα προσέγγιση, το Zero Trust, η οποία ανταποκρίνεται στις απαιτήσεις των σύγχρονων επιχειρησιακών πληροφοριακών συστημάτων. Τα παραδοσιακά μοντέλα, βασισμένα στην έννοια της εμπιστοσύνης εντός του δικτύου, αποδεικνύονται ανεπαρκή σε περιβάλλοντα με αυξημένη διασυνδεσιμότητα, χρήση cloud υποδομών και απομακρυσμένη εργασία.

Η ανάλυση έδειξε ότι το Zero Trust μεταβάλλει ριζικά το μοντέλο ελέγχου πρόσβασης, μετατοπίζοντας την ασφάλεια από το δίκτυο στην ταυτότητα και στα συμφραζόμενα δεδομένα. Η συνεχής επαλήθευση, η εφαρμογή ελάχιστων δικαιωμάτων και η υπόθεση παραβίασης επιτρέπουν πιο αποτελεσματική προστασία των δεδομένων και περιορισμό της εξάπλωσης επιθέσεων.

Παράλληλα, η αξιολόγηση της εφαρμογής του μοντέλου σε επιχειρησιακά περιβάλλοντα κατέδειξε ότι το Zero Trust προσφέρει αυξημένη ευελιξία και προσαρμοστικότητα, υποστηρίζοντας κατανεμημένες υποδομές και σύγχρονες μορφές εργασίας. Ωστόσο, η υλοποίησή του συνοδεύεται από αυξημένη πολυπλοκότητα και κόστος, καθώς απαιτεί ανασχεδιασμό αρχιτεκτονικής, ενσωμάτωση πολλαπλών τεχνολογιών και ώριμη διαχείριση ταυτότητας.

Συνολικά, το Zero Trust δεν αποτελεί απλώς μία εναλλακτική λύση ασφάλειας, αλλά έναν αναγκαίο μετασχηματισμό για τις σύγχρονες επιχειρήσεις. Η υιοθέτησή του αναμένεται να ενισχυθεί περαιτέρω στο μέλλον, ιδιαίτερα με την ενσωμάτωση τεχνολογιών όπως η τεχνητή νοημοσύνη και η αυτοματοποίηση, οι οποίες καθιστούν την ασφάλεια πιο δυναμική και προσαρμοστική.

7. Βιβλιογραφία

 National Institute of Standards and Technology. *Zero Trust Architecture (SP 800-207)*.
 Microsoft. *Zero Trust Overview*.
 Google. *BeyondCorp: A New Approach to Enterprise Security*.
 Cloudflare. *What is Zero Trust?*
 Fortinet. *Zero Trust Security Model*.
 CrowdStrike. *Zero Trust Security Overview*.
 Tufin. *Perimeter Security vs Zero Trust*.

 FIDO Alliance. *FIDO2 Specifications*.